Universidad Politécnica de San Luis Potosí

Propuesta de Gobernanza y Seguridad de la Información

(SGSI ISO/IEC 27001)

Presentado por:

Christian Alfredo Morales Meza - 184937

Asignatura: CNO IV Seguridad Informática

Profesor: Servando López Contreras

Fecha de entrega: 13/10/2026

Índice de contenido

Índice de contenido 2
1. Alcance 3
La organización 3
Estructura y responsables 4
Qué es ISO/IEC 27001 5
Alcance del SGSI 6
2. Referencias normativas 6
Normas ISO/IEC de interés 6
Marcos técnicos complementarios 7
Marco legal y regulatorio 7
3. Términos y condiciones 9
4. Contexto de la organización 9
Activos internos 10
Activos externos 11
5. Liderazgo 11
Política general de seguridad de la información 11
Funciones, supervisión y consecuencias 12
Políticas funcionales de activos internos 12
Políticas funcionales de activos externos 14
6. Planificación 16
Método 16
Matriz de riesgos 16
Cómo se administra el riesgo 20

7. Soporte 21

Flyer de prevención: «Protege tu cuenta y tus datos» 23

8. Operación 24

Ciclo PDCA 24

Matriz RACI 24

9. Evaluación del desempeño 26

Lista de verificación de auditoría 26

Indicadores de desempeño 28

10. Mejora 28

Cambios de políticas funcionales que no lograron el objetivo 28

Flyer rediseñado: «La seguridad también es tarea de todos» 29

1. Alcance

Se propone implantar un SGSI conforme a ISO/IEC 27001:2022 en la Dirección de Tecnologías e Innovación de INTERAFAS, porque su Portal ciudadano y la interfaz con la red OT acumularon 20 hallazgos en INTERAFAS-LAB, 9 de ellos críticos.

La organización

INTERAFAS coordina servicios de agua potable, alcantarillado y saneamiento con enfoque metropolitano, continuidad operacional y atención ciudadana. Opera como organismo intermunicipal desde 2008, integra a tres municipios desde 2014 y sostiene el servicio con 486 personas.

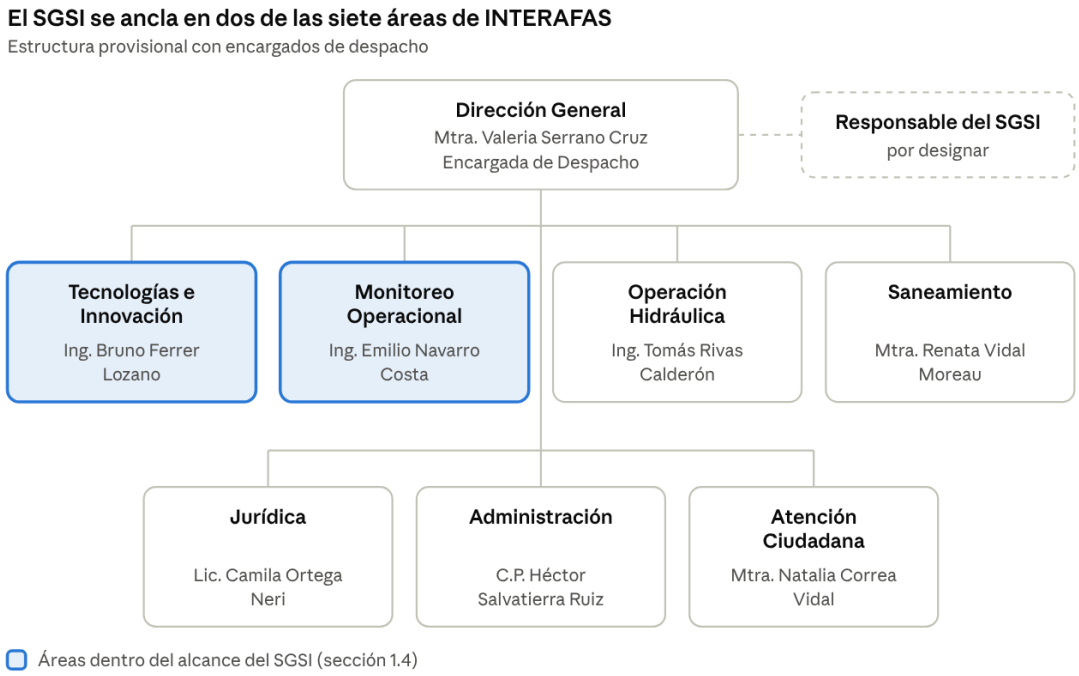
Elemento	Definición institucional
Misión	Gestionar agua con visión metropolitana: prestar servicios esenciales mediante infraestructura, conocimiento técnico, atención ciudadana y coordinación entre municipios.

Visión	Una red resiliente y medible: integrar operación, mantenimiento, información y transparencia para sostener servicios confiables frente a cambios y contingencias.
Principios	Continuidad, resiliencia, transparencia, eficiencia y servicio.

La trayectoria muestra por qué crece el riesgo informático: 1998 automatización del bombeo principal; 2004 centro de operación hidráulica; 2017 cartografía digital; 2021 atención ciudadana digital; 2023 telemetría; 2025 programas de respaldo y gestión de riesgos; 2026 Observatorio Hídrico Metropolitano. Cada etapa añadió sistemas que procesan, almacenan o transmiten información.

Estructura y responsables

Tras las separaciones y suspensiones derivadas de la crisis, el organismo opera con encargadurías de despacho provisionales hasta que los órganos competentes determinen responsabilidades. Esta propuesta asigna funciones a quienes ocupan hoy esos despachos, no a los titulares que aún figuran en el directorio institucional.



Las áreas resaltadas forman el alcance propuesto del SGSI; el cargo de responsable del SGSI se crea con esta propuesta y reporta a la Dirección General.

Área	**Responsable vigente**
Dirección General	Mtra. Valeria Serrano Cruz (Encargada de Despacho)
Operación Hidráulica	Ing. Tomás Rivas Calderón (Encargado de Despacho)
Saneamiento	Mtra. Renata Vidal Moreau (Encargada de Despacho)
Tecnologías e Innovación	Ing. Bruno Ferrer Lozano (Encargado de Despacho)
Jurídica	Lic. Camila Ortega Neri (Encargada de Despacho)
Administración	C.P. Héctor Salvatierra Ruiz (Encargado de Despacho)
Atención Ciudadana	Mtra. Natalia Correa Vidal (Encargada de Despacho)
Monitoreo Operacional	Ing. Emilio Navarro Costa (Encargado de Despacho)

Qué es ISO/IEC 27001

ISO/IEC 27001 es el estándar internacional para establecer, implementar, mantener y mejorar un Sistema de Gestión de Seguridad de la Información (SGSI). Pide decidir con base en riesgos, no en herramientas sueltas, y organiza el trabajo en las cláusulas 4 a 10 (contexto, liderazgo, planificación, soporte, operación, evaluación y mejora) más un Anexo A de 93 controles agrupados en cuatro temas: organizacionales, de personas, físicos y tecnológicos. Es certificable por un organismo externo.

Los argumentos para la Alta Dirección salen de la evidencia propia de INTERAFAS-LAB:

- **El riesgo ya está demostrado.** Los 20 hallazgos (9 críticos, 7 altos, 4 medios) se explotaron con un navegador, Burp Suite, sqlmap y Hashcat. La cadena RT-15 a RT-20 llegó a una condición catastrófica simulada en el proceso industrial.
- **La causa raíz es de gobierno.** El informe señala confianza excesiva en datos del cliente, higiene de despliegue deficiente e inventario de endpoints incompleto. Eso se corrige con políticas, roles, gestión de riesgos y mejora continua, que es lo que exige la norma.

- **Hay datos personales y obligaciones legales.** RT-03 y RT-12 exponen CURP, domicilio e historial financiero de cualquier ciudadano registrado.
- **El servicio es esencial.** La continuidad es un principio de INTERAFAS, y con una estructura provisional el SGSI da permanencia a responsabilidades que hoy dependen de personas.

Alcance del SGSI

Elemento	Definición propuesta
Dirección	Tecnologías e Innovación (Ing. Bruno Ferrer Lozano, Encargado de Despacho)
Área	Ingeniería y tecnología, con Monitoreo Operacional como interfaz hacia la red OT
Proceso	Desarrollo, despliegue y operación del Portal INTERAFAS (web y API) y su integración con el Centro de Operaciones/HMI y la red OT OPS-NET-20
Activos incluidos	Los 20 activos de información de la Sección 4
Fuera de alcance	Sistemas administrativos internos y plantas no conectadas a OPS-NET-20; en la fase de laboratorio, ataques de denegación de servicio e ingeniería social contra personas reales
Hallazgos que lo justifican	RT-01 a RT-20 del Informe de Seguridad Ofensiva

2. Referencias normativas

De la familia ISO/IEC 27000 se seleccionan 14 normas de interés para INTERAFAS, y se suman los marcos técnicos que el informe ya cita y las leyes que el organismo debe cumplir por manejar datos personales, información pública y servicios de agua.

Normas ISO/IEC de interés

Norma	Qué es	Por qué aplica a INTERAFAS	Prioridad
ISO/IEC 27000	Vocabulario y principios de los SGSI	Fuente de los términos de la Sección 3	Alta
ISO/IEC 27001:2022	Requisitos para establecer, mantener y mejorar un SGSI	Norma certificable que estructura este documento	Alta
ISO/IEC 27002:2022	Guía de 93 controles de seguridad	Base de las 20 políticas funcionales de la Sección 5	Alta
ISO/IEC 27005	Gestión de riesgos de seguridad de la información	Metodología de la matriz 5×5 de la Sección 6	Alta

ISO/IEC 27035	Gestión de incidentes de seguridad	Respuesta ante fallas como la cadena RT-15 a RT-20	Alta
ISO/IEC 27003	Guía de implantación del SGSI	Plan de proyecto ante la Alta Dirección	Media
ISO/IEC 27004	Seguimiento, medición y análisis del SGSI	Indicadores de la Sección 9	Media
ISO/IEC 27007	Directrices para auditar un SGSI	Diseño de las listas de verificación	Media
ISO/IEC 27017 y 27018	Controles para servicios en la nube y protección de datos personales en nube pública	Respaldos y alojamiento con terceros (E-06)	Media
ISO/IEC 27019	Controles para sistemas de control de procesos del sector energético	Referencia análoga para OT hídrica; no cubre agua de forma directa	Media
ISO/IEC 27031	Preparación de las TIC para la continuidad del negocio	La continuidad es principio institucional	Media
ISO/IEC 27036	Seguridad en relaciones con proveedores	Proveedores de firmware, pagos y hosting (E-02, E-04, E-05)	Media
ISO/IEC 27701	Extensión de privacidad al SGSI	CURP, domicilio y expedientes de ciudadanos	Media

Marcos técnicos complementarios

Marco	**Uso en la propuesta**
IEC 62443	Seguridad de sistemas de automatización y control industrial; segmentación IT/OT (RT-16, RT-17)
NIST SP 800-82	Guía de seguridad para sistemas de control industrial, citada en el informe
OWASP Top 10:2021 y API Security Top 10:2023	Clasificación de los hallazgos web y de API
CWE y MITRE ATT&CK for ICS	Catálogo de debilidades y tácticas, citados en cada hallazgo
ISO 22301 e ISO 31000	Continuidad del negocio y principios de gestión de riesgo
NMX-I-27001-NYCE	Norma mexicana equivalente a ISO/IEC 27001 (versión 2015, basada en 27001:2013)

Marco legal y regulatorio

El listado parte del orden federal y baja al estatal.

Ordenamiento	Qué obliga	Relación con los hallazgos
Constitución Política (arts. 6, 16 y 115, fr. III)	Derecho a la información y a la protección de datos personales; servicio de agua potable, drenaje y saneamiento a cargo del municipio	Fundamento de todo el SGSI
Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados (nueva, DOF 20-03-2025; última reforma 14-11-2025)	Deber de seguridad, documento de seguridad y atención de vulneraciones	RT-03, RT-07, RT-09, RT-12
Ley General de Transparencia y Acceso a la Información Pública (nueva, DOF 20-03-2025)	Publicar información pública y proteger la reservada o confidencial; las funciones del INAI pasaron a la Secretaría Anticorrupción y Buen Gobierno	RT-04, RT-05 (módulo de transparencia)
Leyes estatales de transparencia y de protección de datos personales de San Luis Potosí	Reglas locales equivalentes y autoridad garante estatal	Verificar nombre y versión con Jurídica
Ley General de Archivos	Gestión, conservación y respaldo de documentos	Respaldos residuales (RT-04)
Ley General de Responsabilidades Administrativas	Faltas de personas servidoras públicas, incluido el uso indebido de información	Consecuencias por incumplir políticas
Código Penal Federal, arts. 211 bis 1 a 211 bis 7	Delitos de acceso ilícito a sistemas y equipos informáticos	Marco para denunciar un incidente
Ley de Aguas Nacionales, NOM-127-SSA1 y NOM-001-SEMARNAT-2021	Calidad del agua y de las descargas, con reportes a autoridades	Integridad de telemetría y datos de proceso (RT-17, RT-20)
Ley Orgánica del Municipio Libre de SLP, leyes estatales de agua y decreto o convenio de creación del organismo intermunicipal	Facultades, órganos de gobierno y reglamento interior de INTERAFAS	Documentos por solicitar a Jurídica
Ley de adquisiciones aplicable (federal o estatal, según el origen del recurso)	Licitaciones y contratos con proveedores	RT-07, RT-14 (validación de referencias y vínculos contractuales)

3. Términos y condiciones

De los 81 términos de ISO/IEC 27000 se definen 12 que la Alta Dirección necesita manejar con el mismo significado para decidir, aprobar presupuesto y exigir resultados.

Término	**Definición**	**Ejemplo en INTERAFAS-LAB**
Información	Dato con significado para la organización, en cualquier medio	Expediente ciudadano con CURP y domicilio
Activo de información	Todo lo que procesa, almacena o transmite información y tiene valor	Base de datos interafas HMI, firmware
Confidencialidad	Que la información solo llegue a quien está autorizado	Roto en RT-03: un usuario lee el expediente de otro
Integridad	Que la información sea exacta y no se altere sin autorización	Rota en RT-13: el pago se liquida con un importe manipulado
Disponibilidad	Que la información y los sistemas funcionen cuando se necesitan	En riesgo en RT-20: co ndición catastrófica simulada en el proceso
Amenaza	Causa potencial de un incidente que puede dañar un activo	Un atacante que explota un parámetro editable
Vulnerabilidad	Debilidad de un activo o control que una amenaza puede aprovechar	Cookie de rol sin firma (RT-06)
Riesgo	Efecto de la incertidumbre sobre los objetivos; aquí, probabilidad por impacto	Fuga de datos personales: 5 × 5 = 25
Control	Medida que mantiene o modifica un riesgo (política, proceso, técnica, práctica)	Verificar en el servidor que el expediente pertenece a quien lo pide
Incidente de seguridad	Evento no deseado que compromete la información o las operaciones	Instalación de firmware no autorizado (RT-18)
Riesgo residual	Riesgo que permanece después de aplicar los controles	Lo que queda tras corregir RT-03 y aplicar UUID
No conformidad	Incumplimiento de un requisito de la norma o de una política propia	Tarea de limpieza de despliegue declarada y no ejecutada (RT-01)

4. Contexto de la organización

Se identifican 20 activos de información, 10 internos que INTERAFAS controla y 10 externos de los que depende sin controlarlos, y cada uno se liga a los hallazgos que lo afectaron en INTERAFAS-LAB.

Activos internos

ID	Activo	Qué procesa, almacena o transmite	Responsable	Hallazgos	Criticidad (propiedad)
A-01	Portal web ciudadano (PHP sobre Apache)	Expedientes, facturación, pagos, reportes, transparencia y contrataciones	Tecnologías e Innovación	RT-03, RT-05, RT-08, RT-10, RT-13	Crítica (C, I)
A-02	API del portal (/api/*)	Historial de servicio, contexto de cuenta, estado de infraestructura	Tecnologías e Innovación	RT-11, RT-12, RT-15	Alta (C)
A-03	Base de datos `interafas` (32 tablas)	Datos personales, financieros y de validación	Tecnologías e Innovación	RT-07	Crítica (C, I, D)
A-04	Servidor Apache 2.4.68 y código fuente	Archivos del document root y código PHP	Tecnologías e Innovación	RT-04, RT-09	Alta (C, I)
A-05	Pipeline de despliegue y artefactos de release	Paquetes ZIP, manifiestos, registros y tokens de validación	Tecnologías e Innovación	RT-01, RT-02	Alta (C, I)
A-06	Cuentas, sesiones y credenciales	Cookies de sesión y de rol, contraseñas, verificador SHA-1 heredado	Tecnologías e Innovación	RT-06, RT-10, RT-18	Crítica (C, I)
A-07	Centro de Operaciones, HMI y telemetría	Niveles, caudal, presión, energía y estado de equipos	Monitoreo Operacional	RT-17, RT-19	Crítica (I, D)
A-08	Red OT OPS-NET-20 (10.40.20.0/24) y gateway	Tráfico entre la red web y la red operacional	Monitoreo Operacional	RT-15, RT-16	Crítica (I, D)
A-09	Firmware y controladores de proceso (bombeo)	Paquetes de actualización y presión de consigna	Operación Hidráulica	RT-18, RT-20	Crítica (I, D)
A-10	Personal interno de TI, operación y atención	Conocimiento, accesos y decisiones de despliegue	Administración	RT-01, RT-04	Alta (C, I, D)

Activos externos

ID	Activo	Qué procesa, almacena o transmite	Área que gestiona la relación	Hallazgos	Criticidad (propiedad)
E-01	Ciudadanos usuarios del portal	CURP, correo, teléfono, domicilio e historial financiero	Atención Ciudadana	RT-03, RT-12	Crítica (C)
E-02	Proveedores y contratistas	Padrón, licitaciones y contratos	Administración	RT-06, RT-07, RT-14	Alta (I)
E-03	Navegadores y equipos de los ciudadanos	Sesiones y contenido que el portal les hace ejecutar	Atención Ciudadana	RT-08, RT-10	Media (C, I)
E-04	Servicio de pagos y facturación	Cuentas, recibos e importes	Administración	RT-13	Alta (I)
E-05	Proveedor de firmware y soporte OT	Paquetes y manifiestos de firmware	Operación Hidráulica	RT-18	Crítica (I)
E-06	Alojamiento, nube y respaldos de terceros	Copias de la base de datos y del portal	Tecnologías e Innovación	RT-01, RT-04	Alta (D)
E-07	Proveedor de telecomunicaciones	Enlaces hacia la telemetría y la red OT	Tecnologías e Innovación	RT-15, RT-17	Alta (D)
E-08	Municipios integrantes	Datos de usuarios e interconexión de redes	Dirección General	RT-15	Media (C, D)
E-09	Autoridades y plataformas de transparencia	Información pública y datos reportados	Jurídica	RT-04, RT-05	Media (C)
E-10	Software y librerías de terceros	Apache, PHP, JavaScript y sistema operativo	Tecnologías e Innovación	RT-01, RT-09	Alta (I, D)

5. Liderazgo

La Dirección General respalda el SGSI con una política general de seguridad de la información y 20 políticas funcionales, una por activo, cada una con estándar, directriz, procedimiento y línea base.

Política general de seguridad de la información

INTERAFAS protege la confidencialidad, integridad y disponibilidad de la información y de los sistemas que sostienen el servicio de agua potable, alcantarillado y saneamiento, porque de ellos dependen la ciudadanía, la continuidad operacional y la transparencia. Para lograrlo, la Alta Dirección se compromete a:

- cumplir la legislación aplicable y los requisitos de ISO/IEC 27001;
- gestionar los riesgos sobre los activos con una matriz revisada al menos cada seis meses;
- asignar roles, recursos y tiempo del personal al SGSI;
- capacitar a todo el personal y exigir a proveedores medidas equivalentes;
- medir el desempeño y mejorar de forma continua.

Objetivos medibles propuestos: ningún hallazgo crítico abierto más de 30 días, 100 % del personal capacitado cada año y una prueba de restauración de respaldos cada trimestre.

Funciones, supervisión y consecuencias

La Dirección General designa a un **responsable del SGSI**, quien supervisa el cumplimiento de las políticas y reporta a la Alta Dirección; cada política nombra además a quien la supervisa en el área (ver columna «Supervisa»). Cuando alguien no cumple una política, se aplica una escala gradual: recordatorio y reforzamiento de capacitación en la primera falta leve; acta administrativa y revisión de accesos si se repite; y remisión a Jurídica y al órgano de control interno cuando la falta es grave o dolosa, conforme a la Ley General de Responsabilidades Administrativas y la normativa laboral. En proveedores, el incumplimiento se sanciona con las penalizaciones del contrato.

Evidencias de liderazgo que se entregan al auditor: acta de aprobación de la política general, oficio de designación del responsable del SGSI, asignación de presupuesto y minutas de revisión por la Dirección (Sección 7).

Políticas funcionales de activos internos

ID	Política funcional	Estándar (qué debe cumplirse)	Directriz (quién y cómo)	Procedimiento	Línea base	Supervisa
PF-01 (A-01)	En el portal, toda consulta de expedientes, facturas y pagos se autoriza en el servidor	OWASP ASVS nivel 2 y OWASP Top 10:2021 A01	Desarrollo valida la propiedad del objeto en cada endpoint; TI aprueba la liberación	Antes de cada versión se ejecuta la prueba «el usuario A no puede leer ni pagar el objeto del usuario B» y se archiva el resultado	Identificadores UUID, errores genéricos, cookies HttpOnly, Secure y SameSite	Responsable del SGSI

PF-02 (A-02)	Toda API consta en un inventario y exige autenticación y autorización por objeto	OWASP API Security Top 10:2023 (API1 y API9)	TI mantiene el inventario y cada endpoint tiene un dueño	Cada trimestre se compara el tráfico real con el inventario y se retiran los endpoints no documentados	La cuenta se toma de la sesión, no de la URL; límite de peticiones	Tecnologías e Innovación
PF-03 (A-03)	La base de datos solo recibe consultas parametrizadas y cuentas de mínimo privilegio	Consultas preparadas; OWASP Top 10:2021 A03	El administrador de la base define roles; la aplicación usa una cuenta sin privilegios administrativos	Revisión de código y análisis estático en cada cambio; auditoría de cuentas cada trimestre	Sin cuenta root desde la aplicación, registro de consultas, CURP cifrada en reposo	Responsable del SGSI
PF-04 (A-04)	El document root solo contiene archivos que se deben publicar	ISO/IEC 27002 controles 8.4 y 8.9	TI define la lista de archivos publicables; ningún respaldo vive en producción	Escaneo automático del document root antes y después de cada despliegue; alerta ante .bak, .old, .zip o ~	Listado de directorios desactivado, denegación de extensiones no estándar, rutas de archivo acotadas contra path traversal	Tecnologías e Innovación
PF-05 (A-05)	Los artefactos y secretos de despliegue nunca se publican	ISO/IEC 27002 controles 8.25, 8.31 y 8.32	El responsable de despliegue firma la lista de verificación de salida; los secretos viven en una bóveda	El pipeline falla si no se confirma la limpieza posterior; /assets/meta/* se elimina o se restringe	Sin tokens en paquetes, rotación tras cada release, Git como único respaldo	Responsable del SGSI
PF-06 (A-06)	Identidades, roles y sesiones se validan en el servidor y los secretos se guardan con algoritmos vigentes	ISO/IEC 27002 controles 5.15 a 5.18 y 8.5; NIST SP 800-63B	TI administra las cuentas; cada dueño de proceso aprueba los roles	Regenerar la sesión al iniciar sesión; leer el rol de la base de datos, no de una cookie; revisar privilegios cada seis meses	Argon2id o bcrypt en lugar de SHA-1, MFA en cuentas administrativas, expiración de sesión	Responsable del SGSI
PF-07 (A-07)	Todo servicio del HMI exige autenticación propia, sin confiar en la red de origen	IEC 62443-3-3 (identificación y autenticación)	Monitoreo Operacional aprueba accesos; TI los implementa	Alta, cambio y baja de usuarios con autorización escrita; revisión mensual de la bitácora	Autenticación por usuario, solo lectura por defecto, bitácora centralizada	Monitoreo Operacional
PF-08 (A-08)	La red OT se separa de la red web con controles de red, no con encabezados HTTP	IEC 62443-3-2 (zonas y conductos); ISO/IEC 27002 control 8.22	TI y Monitoreo Operacional aprueban cada regla	Solicitud de cambio por regla, revisión trimestral y prueba de segmentación anual	Cortafuegos con denegación por defecto, mTLS o VPN entre zonas, X-Forwarded-For ignorado para acceso, sin metadatos de infraestructura en respuestas públicas	Monitoreo Operacional

PF-09 (A-09)	Solo se instala firmware firmado y dentro de límites de ingeniería validados	IEC 62443-4-2; NIST SP 800-193	Operación Hidráulica aprueba cada actualización; el canal de firmware se separa del de parámetros de proceso	Verificar firma y huella en banco de pruebas, validar la presión de consigna contra límites y registrar con posibilidad de revertir	Firma digital obligatoria, límites definidos en el controlador, doble autorización	Operación Hidráulica
PF-10 (A-10)	Todo el personal con acceso a activos se capacita y conoce sus responsabilidades	ISO/IEC 27002 control 6.3	Administración gestiona la capacitación; TI define temas como higiene de despliegue, secretos y phishing	Inducción al ingreso y capacitación mensual; el personal se clasifica por rol (desarrollo, operación, atención) y recibe contenidos acordes	Cada persona completa un curso de ciberseguridad reconocido con sus credenciales institucionales y archiva su constancia	Administración

Políticas funcionales de activos externos

ID	Política funcional	Estándar (qué debe cumplirse)	Directriz (quién y cómo)	Procedimiento	Línea base	Supervisa
PF-11 (E-01)	Los datos personales de los ciudadanos se tratan con aviso de privacidad, mínimo necesario y notificación de vulneraciones	Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados; ISO/IEC 27701	Atención Ciudadana y Jurídica administran avisos y derechos ARCO; TI protege los datos	Inventario de datos personales y notificación al titular y a la autoridad garante dentro de los plazos legales ante una vulneración	CURP cifrada en reposo y enmascarada en pantalla; documento de seguridad vigente	Jurídica
PF-12 (E-02)	Todo contrato incluye cláusulas de seguridad y la relación contrato-proveedor se valida en el servidor	ISO/IEC 27002 controles 5.19 a 5.22; ISO/IEC 27036	Administración y Jurídica incluyen los requisitos; TI valida técnicamente	Evaluación de seguridad antes de contratar y revisión anual; cambios al padrón con doble aprobación	Cláusulas de confidencialidad, aviso de incidentes y derecho de auditoría; acciones del padrón solo con rol administrativo verificado	Administración
PF-13 (E-03)	El portal no confía en el navegador: toda salida se codifica y toda sesión se protege	OWASP Top 10:2021 A03 (XSS); ASVS capítulo 5	Desarrollo implementa la codificación contextual; Atención Ciudadana canaliza los reportes de usuarios	Pruebas de XSS en cada versión sobre los campos de texto libre, como los reportes; sanitizar al guardar y codificar al mostrar	Content-Security-Policy, cookies HttpOnly y SameSite, sesión nueva al autenticar	Tecnologías e Innovación

PF-14 (E-04)	El importe de una operación se recalcula y valida en el servidor	ISO/IEC 27002 control 8.26; PCI DSS si se acepta tarjeta	Administración define las reglas de cobro; TI las implementa	Conciliación diaria de pagos contra saldos y alerta ante diferencias	Monto tomado de la factura en el servidor, ningún valor de solo lectura se acepta del cliente, bitácora de transacciones	Administración
PF-15 (E-05)	Los paquetes de firmware del proveedor llegan por canal verificado, con firma y cadena de custodia	ISO/IEC 27002 control 5.21; IEC 62443-2-4	Operación Hidráulica es dueña de la relación; TI verifica	Recibir la firma y la huella por un canal independiente, probar en banco y registrar la aceptación	Firma digital obligatoria y cláusula de aviso de vulnerabilidades	Operación Hidráulica
PF-16 (E-06)	Toda información crítica tiene respaldo cifrado, fuera del sitio y con restauración probada	ISO/IEC 27002 controles 8.13 y 5.23; ISO/IEC 27017	TI define frecuencia y retención; Jurídica revisa el contrato	Respaldo diario de la base de datos y semanal completo; prueba de restauración cada trimestre	Regla 3-2-1, cifrado y ninguna copia manual dentro del document root	Tecnologías e Innovación
PF-17 (E-07)	Los enlaces hacia la red OT y la telemetría son redundantes y cifrados	ISO/IEC 27002 controles 8.20, 8.21 y 8.24; IEC 62443	TI contrata niveles de servicio; Monitoreo Operacional define la criticidad	Prueba semestral de conmutación al enlace alterno y revisión del nivel de servicio	Dos rutas o proveedores, VPN o TLS, monitoreo de disponibilidad	Monitoreo Operacional
PF-18 (E-08)	Los datos y accesos compartidos con los municipios se rigen por convenios y mínimo privilegio	ISO/IEC 27002 controles 5.14 y 5.15	La Dirección General firma los convenios; Jurídica los revisa	Acuerdo de intercambio de información por municipio y revisión anual de accesos	Cuentas nominales, canales cifrados y sin metadatos de infraestructura en respuestas	Dirección General
PF-19 (E-09)	Lo que se publica en transparencia se revisa para que no exponga datos personales, código ni errores internos	Ley General de Transparencia y Acceso a la Información Pública; ISO/IEC 27002 controles 5.34 y 8.11	Jurídica clasifica la información; TI publica	Revisión de la clasificación antes de publicar y pruebas de manejo de errores en las exportaciones	Mensajes de error genéricos, detalle solo en bitácora, versiones de prueba y respaldos fuera del servidor público	Jurídica
PF-20 (E-10)	Todo componente de terceros se inventaría, se parchea y se retira al terminar su soporte	ISO/IEC 27002 controles 8.8 y 8.19; CVSS	TI prioriza por CVSS; Monitoreo Operacional autoriza ventanas de cambio en OT	Inventario de versiones, revisión semanal de avisos y parches críticos en 7 días y altos en 30	Apache y PHP con soporte vigente, aplicación con usuario sin privilegios, escaneo de vulnerabilidades mensual	Tecnologías e Innovación

6. Planificación

La evaluación cualitativa de las 20 políticas funcionales deja 9 riesgos críticos, 9 altos y 2 medios, y 18 de ellos se tratan con controles del Anexo A de ISO/IEC 27001:2022.

Método

Cada amenaza se califica de 1 a 5 en probabilidad y en impacto, y el nivel de riesgo es su producto en una matriz de 5×5. La probabilidad se apoya en la explotabilidad que mediría CVSS (vector de ataque, complejidad y privilegios requeridos) y el impacto en sus efectos sobre confidencialidad, integridad y disponibilidad. Los valores de este documento son una propuesta del equipo y deben validarlos los propietarios de los activos.

Valor	Probabilidad	Impacto
1	Muy baja: casi imposible	Insignificante
2	Baja: requiere condiciones raras	Menor: molestia sin daño a datos o servicio
3	Media: posible con varias condiciones	Moderado: afecta un proceso o un conjunto acotado de datos
4	Alta: probable con herramientas públicas	Mayor: datos personales masivos o interrupción de un servicio
5	Muy alta: trivial, se reproduce con el navegador	Crítico: fuga masiva, daño físico o pérdida del servicio esencial

Niveles: 1 a 4 Bajo, 5 a 9 Medio, 10 a 15 Alto, 16 a 25 Crítico. El hecho más grave posible queda en 25.

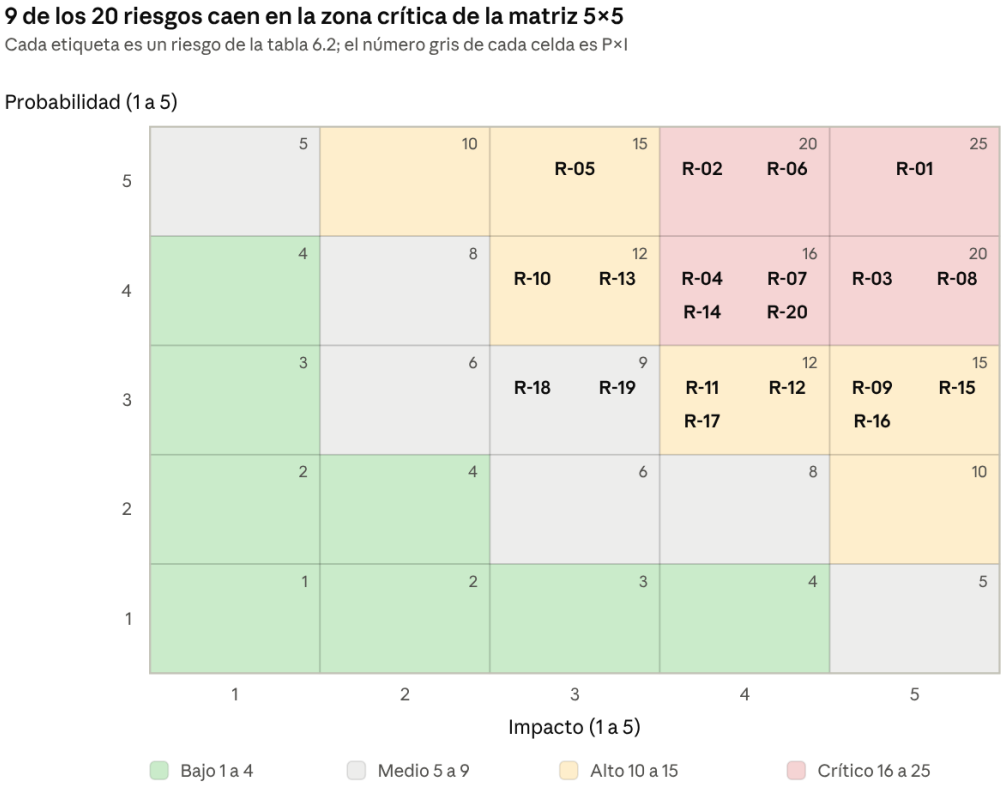
Matriz de riesgos

ID	Activo / política	Amenaza (hallazgo)	P	I	P×I	Nivel	Controles ISO/IEC 27001 Anexo A	Tratamiento
R-01	A-01 / PF-01	Lectura de expedientes de terceros por IDOR (RT-03)	5	5	25	Crítico	5.15, 8.3	Mitigar
R-02	A-02 / PF-02	Acceso cruzado entre cuentas y	5	4	20	Crítico	5.9, 8.3, 8.26	Mitigar

		endpoints no documentados (RT-11, RT-12)						
R-03	A-03 / PF-03	Extracción de la base de datos por inyección SQL ciega (RT-07)	4	5	20	Crítico	8.26, 8.28, 8.29	Mitigar
R-04	A-04 / PF-04	Lectura de código y archivos del servidor por .bak y path traversal (RT-04, RT-09)	4	4	16	Crítico	8.4, 8.9, 8.28	Mitigar
R-05	A-05 / PF-05	Reconocimiento a partir de artefactos y tokens expuestos (RT-01, RT-02)	5	3	15	Alto	5.17, 8.25, 8.31, 8.32	Evitar
R-06	A-06 / PF-06	Escalamiento de privilegios por cookie de rol y fijación de sesión (RT-06, RT-10)	5	4	20	Crítico	5.15, 5.18, 8.2, 8.5	Mitigar
R-07	A-07 / PF-07	Consulta de telemetría sin autenticación (RT-17, RT-19)	4	4	16	Crítico	8.3, 8.5, 8.15	Mitigar
R-08	A-08 / PF-08	Evasión de la segmentación IT/OT con X-Forwarded-For y fuga de topología (RT-15, RT-16)	4	5	20	Crítico	8.20, 8.22, 8.27	Mitigar
R-09	A-09 / PF-09	Firmware no autorizado y presión de consigna fuera	3	5	15	Alto	8.19, 8.24, 8.32	Mitigar

		de límites (RT-18, RT-20)						
R-10	A-10 / PF-10	Errores de despliegue por falta de capacitación y tareas de limpieza sin cerrar (RT-01, RT-04)	4	3	12	Alto	5.37, 6.3, 6.8	Mitigar
R-11	E-01 / PF-11	Suplantación o fraude con CURP y domicilio filtrados (consecuencia de RT-03)	3	4	12	Alto	5.34, 8.11, 8.24	Mitigar
R-12	E-02 / PF-12	Falsificación del vínculo contrato-proveedor y manipulación del padrón (RT-06, RT-14)	3	4	12	Alto	5.19, 5.20, 8.26	Mitigar
R-13	E-03 / PF-13	Ejecución de script malicioso en el navegador del ciudadano por XSS almacenado (RT-08)	4	3	12	Alto	8.26, 8.28	Mitigar
R-14	E-04 / PF-14	Liquidación de adeudos con importe manipulado (RT-13)	4	4	16	Crítico	8.15, 8.26, 8.28	Mitigar
R-15	E-05 / PF-15	Paquete de firmware falso o manipulado en la cadena de suministro (RT-18)	3	5	15	Alto	5.21, 5.22, 8.24	Mitigar y transferir
R-16	E-06 / PF-16	Pérdida de respaldos o	3	5	15	Alto	5.23, 8.13, 8.14	Mitigar

		dependencia sin restauración probada (RT-04)						
R-17	E-07 / PF-17	Interrupción o interceptación de enlaces hacia la red OT (RT-17)	3	4	12	Alto	8.14, 8.20, 8.21	Mitigar y transferir
R-18	E-08 / PF-18	Fuga de topología de infraestructura hacia redes municipales (RT-15)	3	3	9	Medio	5.14, 8.3	Aceptar
R-19	E-09 / PF-19	Exposición de datos no públicos o errores internos en transparencia (RT-04, RT-05)	3	3	9	Medio	5.31, 5.34, 8.11	Mitigar
R-20	E-10 / PF-20	Explotación de una vulnerabilidad 0-day o sin parche en Apache o PHP (RT-09)	4	4	16	Crítico	8.8, 8.9, 8.19	Mitigar



Los 9 riesgos críticos se concentran en la esquina de alta probabilidad e impacto, y el único en 25 es la lectura de expedientes ajenos (R-01).

Cómo se administra el riesgo

Tratamiento	Cuándo se usa	Aplicación en esta propuesta	Quién decide
Mitigar	Se reducen probabilidad o impacto con controles	18 riesgos, entre ellos todos los críticos	Propietario del activo con el Responsable del SGSI
Evitar	Se elimina la actividad o exposición que causa el riesgo	R-05: no publicar artefactos de despliegue y retirar los endpoints de metadatos	Propietario del activo
Transferir	Se comparte con un tercero mediante contrato, nivel de servicio o seguro	R-15 y R-17, junto con la mitigación	Administración y Jurídica

Aceptar	El riesgo es Medio o Bajo y su costo de tratamiento supera el beneficio	R-18, con revisión semestral y firma de la Dirección General	Alta Dirección

7. Soporte

El soporte reúne la minuta con la que se da a conocer el SGSI a la Alta Dirección y un flyer de prevención que traduce las amenazas de la matriz en conductas simples para ciudadanía y personal.

Campo	**Contenido**
Asunto	Presentación del SGSI ISO/IEC 27001 para el Portal INTERAFAS y su integración con la red OT
Fecha y lugar	[13/10/2026], sala de juntas de la Dirección General
Preside	Mtra. Valeria Serrano Cruz, Encargada de Despacho de la Dirección General
Participan	Ing. Bruno Ferrer Lozano (Tecnologías e Innovación), Ing. Emilio Navarro Costa (Monitoreo Operacional), Ing. Tomás Rivas Calderón (Operación Hidráulica), Lic. Camila Ortega Neri (Jurídica), C.P. Héctor Salvatierra Ruiz (Administración), Mtra. Natalia Correa Vidal (Atención Ciudadana, que asume la comunicación)

Objetivos de la reunión: dar a conocer qué es un SGSI y por qué lo necesita INTERAFAS, presentar los 20 hallazgos de INTERAFAS-LAB y sus 9 riesgos críticos, y obtener la aprobación del alcance, de la política general y de las primeras acciones.

Resumen de lo expuesto: los hallazgos se repiten por tres causas de gobierno, no de herramientas: confianza en datos que controla el cliente, falta de higiene de despliegue y falta de inventario vivo de activos y endpoints. El SGSI propone 20 políticas funcionales, una matriz de 20 riesgos y un ciclo de mejora continua.

Acuerdos:

N.º	Acuerdo	Responsable	Plazo
1	Aprobar el alcance del SGSI y la política general de seguridad	Dirección General	Inmediato
2	Designar al Responsable del SGSI	Dirección General	5 días hábiles
3	Retirar artefactos de despliegue, archivos .bak y endpoints de metadatos de build (RT-01, RT-02, RT-04)	Tecnologías e Innovación	10 días hábiles
4	Implantar autorización en el servidor para expedientes, API y roles (RT-03, RT-06, RT-12)	Tecnologías e Innovación	30 días
5	Exigir autenticación en el HMI y reforzar la segmentación IT/OT con controles de red (RT-16, RT-17)	Monitoreo Operacional	30 días
6	Exigir firmware firmado y límites de ingeniería en el controlador (RT-18, RT-20)	Operación Hidráulica	60 días
7	Revisar el aviso de privacidad y el documento de seguridad	Jurídica	45 días
8	Lanzar el flyer de prevención y el programa de capacitación	Atención Ciudadana y Administración	15 días

Nombre	Cargo	Firma
Mtra. Valeria Serrano Cruz	Encargada de Despacho, Dirección General	
Ing. Bruno Ferrer Lozano	Encargado de Despacho, Tecnologías e Innovación	
Mtra. Natalia Correa Vidal	Encargada de Despacho, Atención Ciudadana (comunicación)	
Lic. Camila Ortega Neri	Encargada de Despacho, Jurídica	

Flyer de prevención: «Protege tu cuenta y tus datos»



8. Operación

El SGSI opera con el ciclo PDCA y una matriz RACI que fija, para 13 actividades, quién responde, quién aprueba, a quién se consulta y a quién se informa.

Ciclo PDCA

1. **Planificar:** definir alcance, política, inventario de activos, matriz de riesgos y objetivos (Secciones 1 a 6).
2. **Hacer:** implantar los controles de las 20 políticas funcionales, capacitar al personal y operar los procesos con los roles de la matriz RACI (Secciones 7 y 8).
3. **Verificar:** aplicar listas de verificación, medir indicadores y auditar (Sección 9).
4. **Actuar:** corregir las no conformidades y mejorar políticas y soporte, y volver a planificar con lo aprendido (Sección 10).

Matriz RACI

R = Responsable de ejecutar, A = Aprobador final (uno por actividad), C = Consultado, I = Informado, — = no participa. El Responsable del SGSI es una figura que la Dirección General debe designar (acuerdo 2 de la minuta).

Actividad	Dirección General	Resp. SGSI	Tecnologías e Innovación	Monitoreo Operacional	Operación Hidráulica	Jurídica	Administración	Atención Ciudadana
Aprobar política general, alcance y presupuesto	A	R	C	C	C	C	C	I
Mantener el inventario de activos y clasificar la información	I	A	R	R	R	C	I	I
Evaluar riesgos y	A	R	C	C	C	C	C	I

aprobar el plan de tratamiento								
Desarrollo seguro, despliegue y control de cambios del portal y la API (PF-01 a PF-06, PF-13, PF-14)	I	C	A/R	I	—	I	C	C
Gestión de vulnerabilidades y parches (PF-20)	I	C	A/R	C	C	—	—	—
Segmentación IT/OT, HMI y telemetría (PF-07, PF-08)	I	C	R	A	C	—	—	—
Firmware y límites de ingeniería (PF-09, PF-15)	I	C	R	C	A	C	—	—
Proveedores y contratos con cláusulas de seguridad (PF-12, PF-16, PF-17, PF-18)	I	C	C	C	C	R	A	—
Protección de datos personales y transparenc	I	C	R	—	—	A	—	R

ia (PF-11, PF-19)								
Capacitación y concienciación (PF-10 y flyer)	I	C	C	C	C	—	A	R
Respaldo y continuidad (PF-16, PF-17)	I	C	A/R	R	C	I	I	I
Gestión de incidentes y comunicación de crisis	A	R	R	R	C	C	I	R
Auditoría interna y revisión por la Dirección	A	R	C	C	C	C	C	I

9. Evaluación del desempeño

Lista de verificación de auditoría

Se sigue el formato Sí/No de las plantillas de auditoría de INCIBE y las directrices de ISO/IEC 27007. Los resultados se llenaron de forma hipotética para demostrar el ciclo y deben sustituirse por evidencia real en la primera auditoría interna.

N.º	Política	Pregunta de verificación	Evidencia a revisar	¿Cumple?
1	PF-01	¿Cada liberación del portal ejecuta la prueba de autorización por objeto y su resultado está archivado?	Reporte del pipeline	Sí
2	PF-02	¿El inventario de API coincide con el tráfico real revisado este trimestre?	Inventario y bitácora de revisión	Sí
3	PF-03	¿La aplicación usa consultas parametrizadas y una cuenta sin privilegios administrativos?	Revisión de código y roles de la base	Sí
4	PF-04	¿El escaneo del document root no detecta archivos .bak, .old o .zip?	Informe del escaneo automático	Sí

5	PF-05	¿El pipeline bloquea el despliegue si no se confirma la limpieza de artefactos y tokens?	Configuración del pipeline y lista de salida firmada	No
6	PF-06	¿Las contraseñas se guardan con Argon2id o bcrypt y las cuentas administrativas usan MFA?	Configuración de autenticación	No
7	PF-07	¿Todo servicio del HMI exige autenticación y la bitácora se revisa cada mes?	Pruebas de acceso y actas de revisión	Sí
8	PF-08	¿Cada regla del cortafuegos IT/OT tiene solicitud de cambio y la prueba anual de segmentación está hecha?	Solicitudes de cambio e informe de prueba	Sí
9	PF-09	¿Cada firmware instalado tiene firma verificada y límites de presión validados?	Registro de instalaciones	Sí
10	PF-10	¿Más de 90 % del personal completó la capacitación vigente?	Constancias de capacitación	No
11	PF-11	¿El aviso de privacidad y el documento de seguridad están vigentes?	Documentos con fecha de revisión	Sí
12	PF-12	¿Los contratos vigentes incluyen cláusulas de seguridad y aviso de incidentes?	Contratos del padrón	No
13	PF-13	¿El portal envía Content-Security-Policy y codifica la salida de los reportes ciudadanos?	Cabeceras HTTP y prueba de XSS	No
14	PF-14	¿La conciliación diaria de pagos se realizó y no hay diferencias abiertas?	Reporte de conciliación	Sí
15	PF-15	¿Los paquetes de firmware llegaron con firma y huella por un canal independiente?	Registro de recepción	Sí
16	PF-16	¿La última prueba trimestral de restauración de respaldos fue exitosa?	Acta de la prueba	No
17	PF-17	¿Existe un enlace alterno y se probó la conmutación este semestre?	Informe de la prueba	Sí
18	PF-18	¿Cada municipio tiene convenio de intercambio y revisión anual de accesos?	Convenios y lista de accesos	Sí
19	PF-19	¿La revisión de clasificación antes de publicar en transparencia está documentada?	Formato de revisión	Sí
20	PF-20	¿Apache y PHP tienen soporte vigente y los parches críticos se aplicaron en 7 días?	Inventario de versiones y registro de parches	Sí

Indicadores de desempeño

Indicador	Cómo se calcula	Meta	Resultado hipotético
Cumplimiento de la lista de verificación	Puntos con «Sí» entre 20	90 % o más	70 % (14 de 20)
Riesgos críticos con tratamiento activo	Críticos con plan en marcha entre 9	100 %	100 %
Personal capacitado	Personas con curso vigente entre 486	90 % o más	Por medir en la primera auditoría
Pruebas de restauración exitosas	Pruebas exitosas entre las programadas	4 al año	0 de 1 en el trimestre evaluado

10. Mejora

Los 6 incumplimientos de la lista de verificación se tratan como no conformidades: cada una recibe una política funcional corregida y un soporte de prevención rediseñado, y la prioridad es la contraseña, porque combina el hallazgo del verificador SHA-1 heredado con el comportamiento diario del usuario.

Cambios de políticas funcionales que no lograron el objetivo

ID	Política	Requisito reformulado	Evidencia
PF-05	Limpieza de artefactos y secretos	Bloquear el despliegue hasta eliminar respaldos, paquetes, credenciales y tokens; exigir lista de salida firmada.	Pipeline y lista firmada.
PF-06	Contraseñas y autenticación	Almacenar contraseñas con Argon2id o bcrypt y exigir MFA en todas las cuentas administrativas.	Configuración de autenticación.
PF-10	Capacitación en seguridad	Lograr que al menos el 90 % del personal complete la capacitación vigente y conservar las constancias.	Constancias de capacitación.
PF-12	Seguridad contractual y proveedores	Incluir cláusulas de seguridad en todos los contratos y validar roles y aprobaciones para cambios en el padrón.	Contratos y registros de aprobación.
PF-13	Protección contra XSS y sesiones	Codificar las salidas, configurar CSP y cookies seguras, renovar la sesión al autenticar y probar XSS en cada versión.	Cabeceras HTTP y pruebas XSS.
PF-16	Respaldos y recuperación	Cifrar respaldos, conservarlos fuera del sitio y probar la restauración cada trimestre.	Registros de respaldo y acta de restauración.

Flyer rediseñado: «La seguridad también es tarea de todos»

